Rafael Angelo Christianto

HACK THE BOX SHERLOCK - THREAT INTELLIGENCE UFO-1

MITRE ATT&CK Sandworm Team - https://attack.mitre.org/groups/G0034/

This is the Threat Intelligence Sherlock that do not have a PCAP, log, or any files to be downloaded, and only depend on internet searching skills, and reading the MITRE ATT&CK website.

1. According to the sources cited by Mitre, in what year did the Sandworm Team begin operations?

Sandworm Team

Sandworm Team is a destructive threat group that has been attributed to Russia's General Staff Main Intelligence Directorate (GRU) Main Center for Special Technologies (GTsST) military unit 74455.[1][2] This group has been active since at least 2009.[3][4][5][6]

In October 2020, the US indicted six GRU Unit 74455 officers associated with Sandworm Team for the following cyber operations: the 2015 and 2016 attacks against Ukrainian electrical companies and government organizations, the 2017 worldwide NotPetya attack, targeting of the 2017 French presidential campaign, the 2018 Olympic Destroyer attack against the Winter Olympic Games, the 2018 operation against the Organisation for the Prohibition of Chemical Weapons, and attacks against the country of Georgia in 2018 and 2019.[1][2] Some of these were conducted with the assistance of GRU Unit 26165, which is also referred to as APT28.[7]

ID: G0034
Associated Groups: ELECTRUM, Telebots, IRON VIKING, BlackEnergy (Group), Quedagh, Voodoo Bear, IRIDIUM, Seashell Blizzard, FROZENBARENTS, APT44
Contributors: Dragos Threat Intelligence; Hakan KARABACAK
Version: 4.2
Created: 31 May 2017
Last Modified: 04 December 2024

Version Permalink

As highlighted in the screenshot above, the Sandworm Team has been active since **2009**.

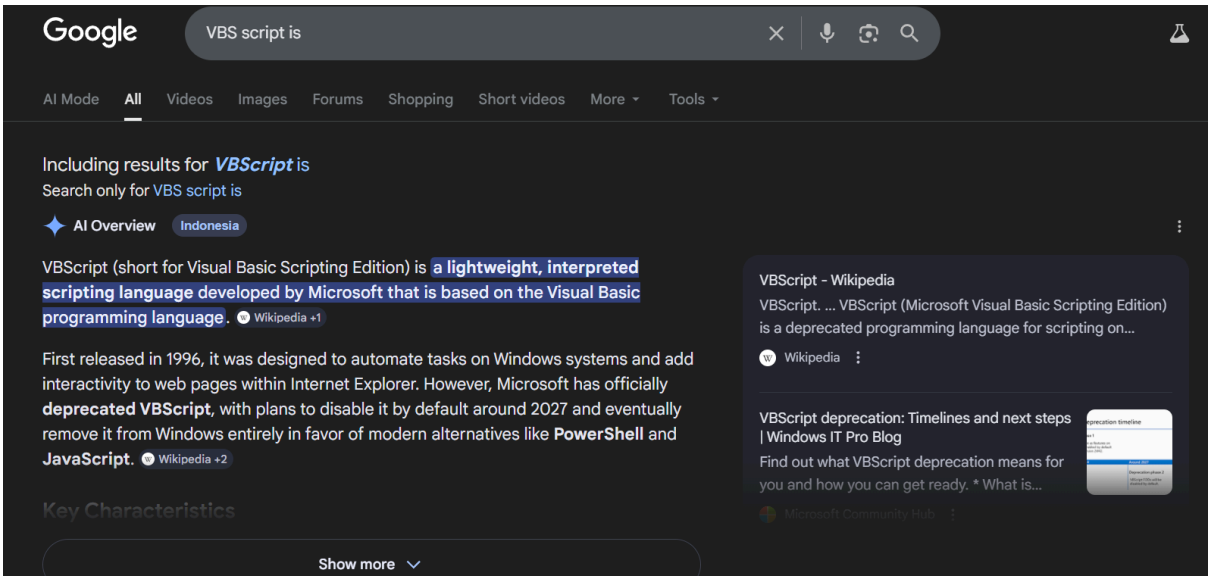
2. Mitre notes two credential access techniques used by the BlackEnergy group to access several hosts in the compromised network during a 2016 campaign against the Ukrainian electric power grid. One is LSASS Memory access (T1003.001). What is the Attack ID for the other?

Enterprise	T1110	Brute Force	During the 2016 Ukraine Electric Power Attack, Sandworm Team used a script to attempt RPC authentication against a number of hosts.[18]

Since it happened in 2016, I searched in the description column for the 2016 Ukraine Electric Power Attack. Then I searched for those who are involved in credential access techniques, which in this case there is a

script to attempt RPC authentication to several hosts, and the attack ID is **T1110**.

3. During the 2016 campaign, the adversary was observed using a VBS script during their operations. What is the name of the VBS file?



I first Googled what VBScript is, and it is a scripting language developed by Microsoft that is based on the Visual Basic programming language.

ICS	T0867	Lateral Tool Transfer	During the 2015 Ukraine Electric Power Attack, Sandworm Team moved their tools laterally within the ICS network. [15] During the 2016 Ukraine Electric Power Attack, Sandworm Team used a VBS script to facilitate lateral tool transfer. The VBS script was used to copy ICS-specific payloads with the following command: `cscript C:\Backinfo\ufn.vbs C:\Backinfo\101.dll C:\Delta\101.dll` [18]

Then, still in the MITRE ATT&CK website, I filtered for VBS, and I see a .vbs file called **ufn.vbs**, and that has to be the answer to this question

4. The APT conducted a major campaign in 2022. The server application was abused to maintain persistence. What is the Mitre Att&ck ID for the persistence technique was used by the group to allow them remote access?

Enterprise	T1505	.001	Server Software Component: SQL Stored Procedures	During the 2016 Ukraine Electric Power Attack, Sandworm Team used various MS-SQL stored procedures.[18]
		.003	Server Software Component: Web Shell	Sandworm Team has used webshells including P.A.S. Webshell to maintain access to victim networks.[34] During the 2022 Ukraine Electric Power Attack, Sandworm Team deployed the Neo-REGEORG webshell on an internet-facing server.[20]

P.A.S. Webshell

P.A.S. Webshell is a publicly available multifunctional PHP webshell in use since at least 2016 that provides remote access and execution on target web servers.[1]

ID: S0598
Associated Software: Fobushell
Type: MALWARE
Platforms: Linux, Windows
Version: 1.0
Crea P.A.S. Webshell
Last P.A.S. Webshell is a publicly available multifunctional PHP webshell in use since at least 2016 that provides remote access and execution on target web servers.[1]

From the 2 screenshots above, we can tell that the P.A.S. webshell maintains access to victim networks and provides remote access and execution, so we get the MITRE ATT&CK ID which is **T1505.003**

5. What is the name of the malware / tool used in question 4?

Enterprise	T1505	.001	Server Software Component: SQL Stored Procedures	During the 2016 Ukraine Electric Power Attack, Sandworm Team used various MS-SQL stored procedures.[18]
		.003	Server Software Component: Web Shell	Sandworm Team has used webshells including P.A.S. Webshell to maintain access to victim networks.[34] During the 2022 Ukraine Electric Power Attack, Sandworm Team deployed the Neo-REGEORG webshell on an internet-facing server.[20]

The same screenshot as the first screenshot in question 4, the answer for this question is highlighted which is **Neo-REGEORG**.

6. Which SCADA application binary was abused by the group to achieve code execution on SCADA Systems in the same campaign in 2022?

ICS	T0807	Command-Line Interface	Sandworm Team uses the MS-SQL server xp_cmdshell command, and PowerShell to execute commands. [40] During the 2016 Ukraine Electric Power Attack, Sandworm Team supplied the name of the payload DLL to Industroyer via a command line parameter.[17] During the 2022 Ukraine Electric Power Attack, Sandworm Team leveraged the SCIL-API on the MicroSCADA platform to execute commands through the `scilc.exe` binary.[20]

Here in the screenshot above, we can see in the same 2022 Ukraine Electric Power Attack, the Sandworm Team used the SCIL-API on the MicroSCADA platform to run commands through the **scilc.exe** application binary.

7. Identify the full command line associated with the execution of the tool from question 6 to perform actions against substations in the SCADA environment.

ICS	T0894	System Binary Proxy Execution	During the 2022 Ukraine Electric Power Attack, Sandworm Team executed a MicroSCADA application binary `scilc.exe` to send a predefined list of SCADA instructions specified in a file defined by the adversary, `s1.txt`. The executed command `C:\sc\prog\exec\scilc.exe -do pack\scil\s1.txt` leverages the SCADA software to send unauthorized command messages to remote substations. [20]

In the highlighted section of the screenshot above is the command for SCADA software to send unauthorized commands to substations, which is **C:\sc\prog\exec\scilc.exe -do pack\scil\s1.txt**.

8. What malware/tool was used to carry out data destruction in a compromised environment during the same campaign?

Enterprise	T1485	Data Destruction	Sandworm Team has used CaddyWiper, SDelete, and the BlackEnergy KillDisk component to overwrite files on victim systems. [30][26][20] Additionally, Sandworm Team has used the JUNKMAIL tool to overwrite files with null bytes.[14] During the 2022 Ukraine Electric Power Attack, Sandworm Team deployed CaddyWiper on the victim's IT environment systems to wipe files related to the OT capabilities, along with mapped drives, and physical drive partitions.[20]

During the same 2022 Ukraine Electric Power Attack, the Sandworm Team used **CaddyWiper** on the victim's IT environment to perform data destruction by wiping files related to the OT capabilities.

9. The malware/tool identified in question 8 also had additional capabilities. What is the Mitre Att&ck ID of the specific technique it could perform in Execution tactic?

Task 9

MITRE also records the capabilities and behaviors of tools used by attackers. Go to the MITRE page for the tool. Once there, open the enterprise navigator layer again the same way we have been doing so far. Look for the technique used under the "Execution" tactic. Find the technique ID of the technique by hovering it.

I could not find the answer to this question after searching for it through the website several times, so I opened the hint.

Rafael Angelo Christianto

CaddyWiper

CaddyWiper is a destructive data wiper that has been used in attacks against organizations in Ukraine since at least March 2022.[1][2]

ID: S0693
Type: MALWARE
Platforms: Windows
Version: 1.1
Created: 23 March 2022
Last Modified: 17 April 2024

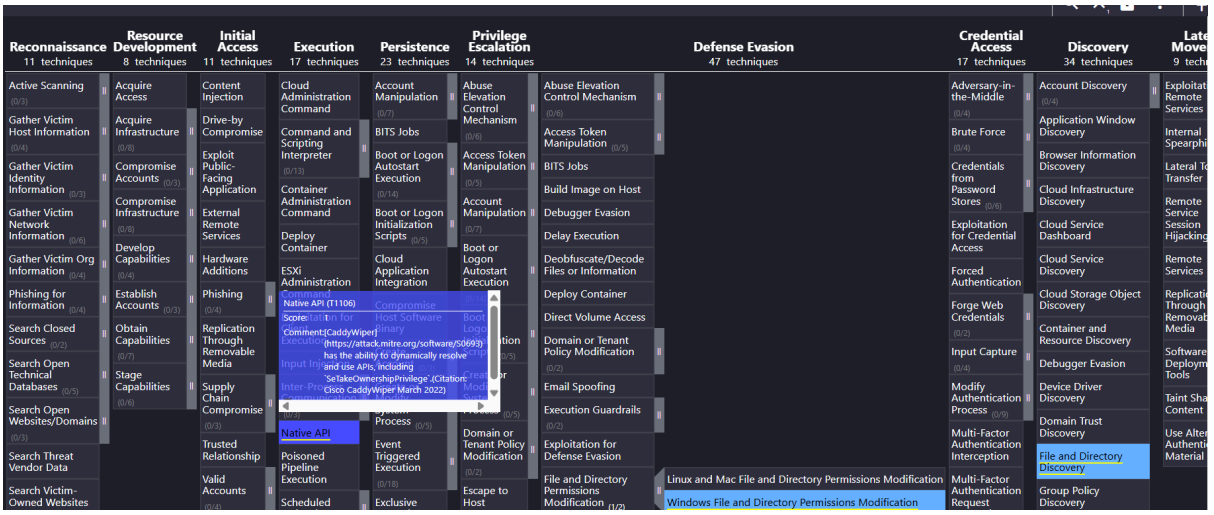
Version Permalink

Techniques Used

ATT&CK® Navigator Layers

Domain	ID		Name	Use
Enterprise	T1485		Data Destruction	CaddyWiper can work alphabetically through drives on a compromised system to take ownership of and overwrite all files.[1][2]
Enterprise	T1561	.002	Disk Wipe: Disk Structure Wipe	CaddyWiper has the ability to destroy information about a physical drive's

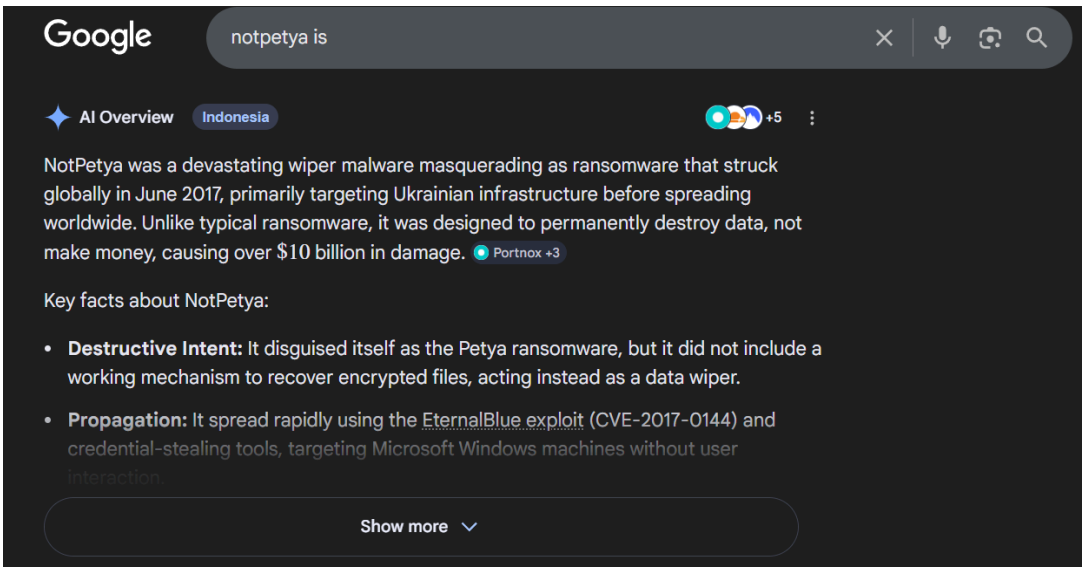
I opened the MITRE ATT&CK website for CaddyWiper and then I select the ATT&CK Navigator Layers.



And immediately I spotted the one under Execution tactic which is Native API, and it has MITRE ATT&CK ID of **T1106**.

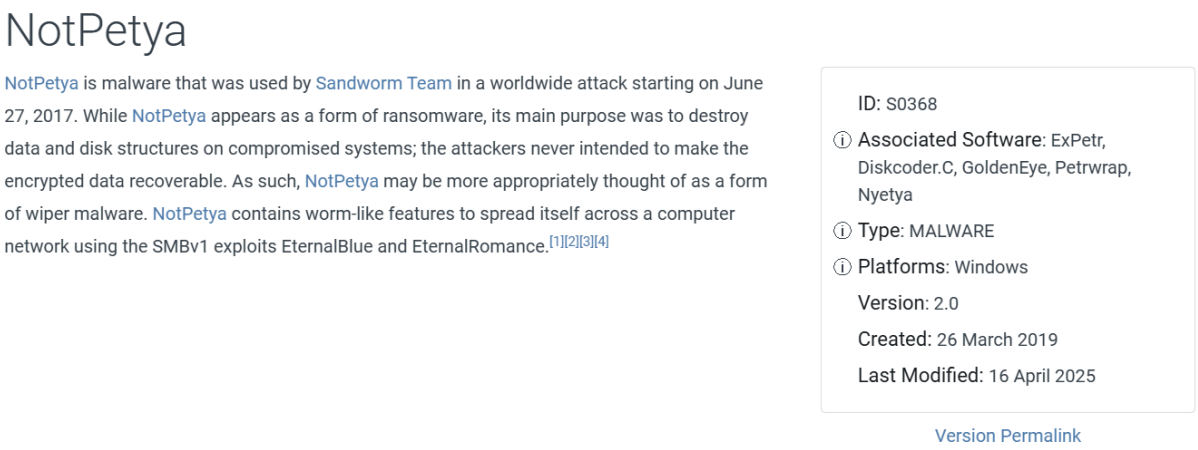
10. The Sandworm Team is known to use different tools in their campaigns. They are associated with an auto-spreading malware that acted as a ransomware while having worm-like features .What is the name of this malware?

Enterprise	T1587	.001	Develop Capabilities: Malware	Sandworm Team has developed malware for its operations, including malicious mobile applications and destructive malware such as NotPetya and Olympic Destroyer.[1]



In the website I found the Sandworm Team uses **NotPetya** which is a wiper malware that masquerades as ransomware and behaves like a worm.

11. What was the Microsoft security bulletin ID for the vulnerability that the malware from question 10 used to spread around the world?



I opened the NotPetya MITRE ATT&CK page and I found the Microsoft security bulletin ID

ICS	T0866	Exploitation of Remote Services	NotPetya initially infected IT networks, but by means of an exploit (particularly the SMBv1-targeting MS17-010 vulnerability) spread to industrial networks. [7]

NotPetya used the SMBv1 **MS17-010** vulnerability to spread across industrial networks, and that is the answer to this question.

12. What is the name of the malware/tool used by the group to target modems?

46. Juan Andres Guerrero-Saade and Max van Amerongen, SentinelOne. (2022, March 31). AcidRain | A Modem Wiper Rains Down on Europe. Retrieved March 25, 2024.

I saw first on this reference like shown in the screenshot above that AcidRain is the malware that targets modems, so I opened AcidRain's MITRE ATT&CK page, like shown in the screenshot below.

AcidRain

AcidRain is an ELF binary targeting modems and routers using MIPS architecture.[1] AcidRain is associated with the ViaSat KA-SAT communication outage that took place during the initial phases of the 2022 full-scale invasion of Ukraine. Analysis indicates overlap with another network device-targeting malware, VPNFilter, associated with Sandworm Team.[1] US and European government sources linked AcidRain to Russian government entities, while Ukrainian government sources linked AcidRain specifically to Sandworm Team.[2][3]

ID: S1125
Type: MALWARE
Platforms: Network Devices, Linux
Version: 1.1
Created: 25 March 2024
Last Modified: 15 April 2025

Version Permalink

Techniques Used

ATT&CK® Navigator Layers

Domain	ID		Name	Use
Enterprise	T1485		Data Destruction	AcidRain performs an in-depth wipe of the target filesystem and various attached storage devices through either a data overwrite or calling various IOCTLS to erase it.[1]
Enterprise	T1561	.001	Disk Wipe: Disk Content Wipe	AcidRain iterates over device file identifiers on the target, opens the device file, and either overwrites the file or calls various IOCTLS commands to erase it.[1]
Enterprise	T1083		File and Directory Discovery	AcidRain identifies specific files and directories in the Linux operating system associated with storage devices.[1]

Then, it is confirmed, **AcidRain** targets modems.

13. Threat Actors also use non-standard ports across their infrastructure for Operational-Security purposes. On which port did the Sandworm team reportedly establish their SSH server for listening?

Enterprise	T1571	Non-Standard Port	Sandworm Team has used port 6789 to accept connections on the group's SSH server.[25]

Here in the screenshot above we can tell that the Sandworm Team opened port **6789** on SSH for listening. It is using a tactic of Non Standard Port

Home > Techniques > Enterprise > Non-Standard Port

Non-Standard Port

Adversaries may communicate using a protocol and port pairing that are typically not associated. For example, HTTPS over port 8088[1] or port 587[2] as opposed to the traditional port 443. Adversaries may make changes to the standard port used by a protocol to bypass filtering or muddle analysis/parsing of network data.

Adversaries may also make changes to victim systems to abuse non-standard ports. For example, Registry keys and other configuration settings can be used to modify protocol and port pairings.[3]

ID: T1571
Sub-techniques: No sub-techniques
Tactic: Command and Control
Platforms: ESXi, Linux, Windows, macOS
Version: 1.3
Created: 14 March 2020
Last Modified: 24 October 2025

Version Permalink

It describes how adversaries may communicate using a mismatch of the protocol and the port like explained in the screenshot above.

14. The Sandworm Team has been assisted by another APT group on various operations. Which specific group is known to have collaborated with them?

Sandworm Team

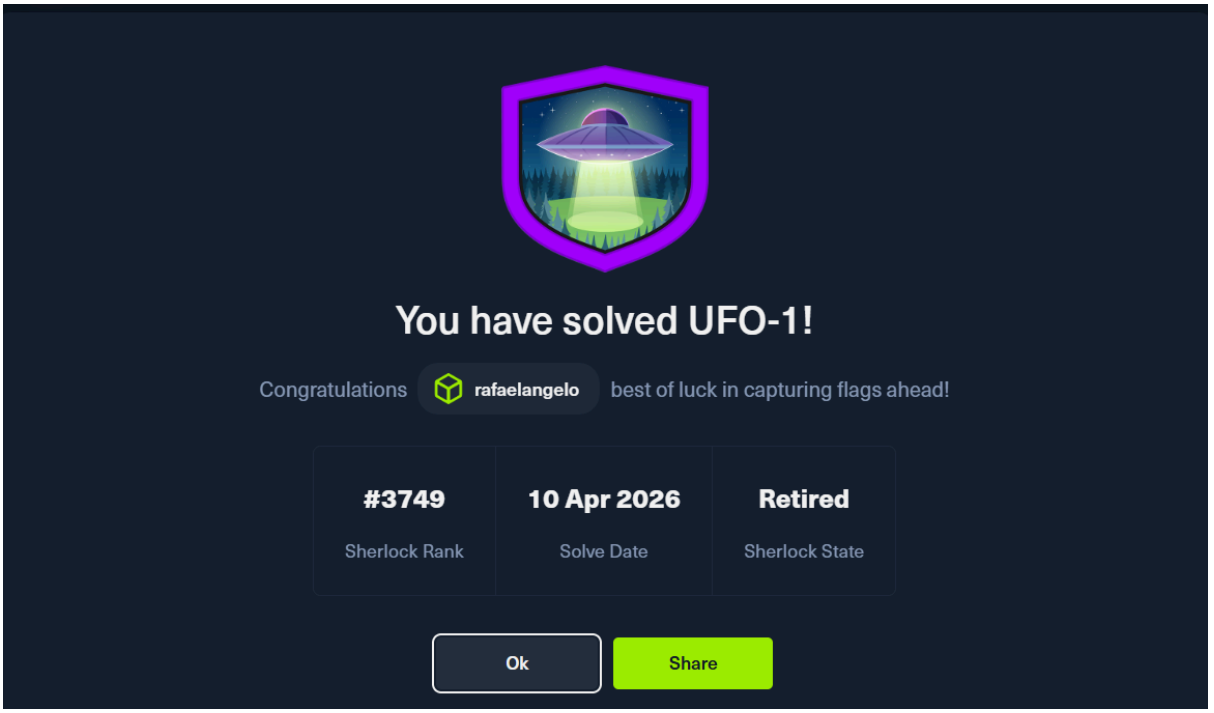
Sandworm Team is a destructive threat group that has been attributed to Russia's General Staff Main Intelligence Directorate (GRU) Main Center for Special Technologies (GTsST) military unit 74455.[1][2] This group has been active since at least 2009.[3][4][5][6]

In October 2020, the US indicted six GRU Unit 74455 officers associated with Sandworm Team for the following cyber operations: the 2015 and 2016 attacks against Ukrainian electrical companies and government organizations, the 2017 worldwide NotPetya attack, targeting of the 2017 French presidential campaign, the 2018 Olympic Destroyer attack against the Winter Olympic Games, the 2018 operation against the Organisation for the Prohibition of Chemical Weapons, and attacks against the country of Georgia in 2018 and 2019.[1][2] Some of these were conducted with the assistance of GRU Unit 26165, which is also referred to as APT28.[7]

ID: G0034
Associated Groups: ELECTRUM, Telebots, IRON VIKING, BlackEnergy (Group), Quedagh, Voodoo Bear, IRIDIUM, Seashell Blizzard, FROZENBARENTS, APT44
Contributors: Dragos Threat Intelligence; Hakan KARABACAK
Version: 4.2
Created: 31 May 2017
Last Modified: 04 December 2024

Version Permalink

Associated Group Descriptions

Seen in the last sentence of the last paragraph, it is said Sandworm Team and GRU Unit 26165 also known as **APT28**, worked together.

Rafael Angelo Christianto